

Operation — Silent Credential Theft

FIN-WS-117 LSASS access → unusual authentication · Ref DSOU-WR-2026-1008-SCT · Detection + response only · TLP:AMBER

CRITICAL

correlation 4/4

H1 + H3

supported · H2 rejected

1 of 28

LSASS accesses
suspicious

4.5 min

access → server logon

14 files

Finance\$ payroll read

20/20

tests pass

Verdict — NOT a false positive. H1 credential access SUPPORTED · H2 legitimate admin REJECTED · H3 credential abuse SUPPORTED · correlation 4/4 → CRITICAL. At 09:40 IST an unsigned binary spawned by Word opened `lsass.exe` with memory-read rights on FIN-WS-117. Within 5 minutes a privileged account (`adm.kiran`) that had never used this workstation as a source logged on to FILE-SRV-03 with explicit credentials, read 14 payroll/treasury files, and 10 minutes after the access appeared on a second workstation. The user is probably telling the truth — her *session* was used, not her hands.

Mission 01 — Initial triage

Primary question — legitimate system behaviour, authorised security software, or credential access? Credential access. Of 28 LSASS access events in 30 days, 27 are the allow-listed readers (`MsmEng.exe` with `0x1000`, the EDR agent with `0x1410`, both signed, both from protected paths). Exactly one is not.

Triage item	Finding (from the hunter)
User logged on	<code>f.rao</code> (Finance, non-privileged) — console logon 09:32:10 IST
Host / IP	FIN-WS-117 · 10.20.31.117
Process that accessed LSASS	<code>C:\Users\f.rao\AppData\Local\Temp\dbgsvc.exe</code>
Parent / command line	<code>WINWORD.EXE → dbgsvc.exe <redacted></code> — an Office app has no reason to spawn a debugger-like binary
Signature / hash	unsigned · <code>SYNTH-SHA256-...117</code> · first-seen, present on this host only
Access mask / time	<code>GrantedAccess 0x1010</code> (includes <code>PROCESS_VM_READ</code>) · 09:40:20 IST
Logon types	Type 2 (user, normal) · Type 3 ×3 outbound (new) · Type 10 by admin on 05 Oct (legit support)
Failed vs successful	6 failed (4625, three account names) → 3 successful Type 3
Source → destinations	FIN-WS-117 → FILE-SRV-03, FIN-WS-121 (0 prior logons to either from this host)
Shares / files	<code>\\FILE-SRV-03\Finance\$</code> — 14 reads in <code>Payroll\</code>
Privileged accounts	<code>adm.kiran</code> (server admin). Exposure cause: his RDP support session on this workstation on 05 Oct (INC-20931)
Other endpoints / changes	hash not seen elsewhere; no software change or admin ticket for today
EDR / AV	EDR raised a credential-access alert on the same process (alert-only, not blocked)

Mission 02 — Hunting hypotheses

	H1 — credential access targeting LSASS	H2 — legitimate administrative activity	H3 — credentials abused for internal access
Verdict	SUPPORTED	REJECTED	SUPPORTED
Evidence found	unapproved image · unsigned · user-writable path · <code>VM_READ</code> mask · Word as parent · EDR alert · hash first-seen	no change/incident ticket · FIN-WS-117 is not an approved admin source (PAW only) · admin tools are not launched by Word	4648 for privileged <code>adm.kiran</code> · 2 new destinations · 14 sensitive reads · second workstation · 4 RC4/first-seen service tickets · 6 failures first
Data sources	Sysmon 1/10, 4688, EDR	AD + change records, 4624 source, PAW range	DC 4769, 4624/4625/4648/4672, file-server 5145
False positives ruled out	Defender + EDR agent accesses stay EXPECTED (27 of 28)	the real admin logon from PAW-ADMIN-01 on 06 Oct with CHG-4471 is scored LEGITIMATE	VPN/remote work would not produce explicit admin credentials from a finance desktop
What would change my mind	the binary turns out to be a signed, approved diagnostic tool pushed by IT	a ticket plus the admin confirming he typed his password on that desk at 09:45	the logons originate from the PAW, in a window, with Kerberos AES

H2 is the important one to *disprove* rather than assume: the same admin account doing the same Type 3 logon to the same server two days earlier is legitimate. Account and destination are identical — only **source host, process lineage and ticket** separate the two.

Mission 03 — Authentication timeline (IST)

Time	Event	What happened
09:32:10	4624 / 2	<code>f.rao</code> logs on to FIN-WS-117 (normal)
09:40:05	4688 + Sysmon 1	<code>WINWORD.EXE → dbgsvc.exe</code> (unsigned, <code>%TEMP%</code>)

Time	Event	What happened
09:40:20	Sysmon 10	dbgsvc.exe opens lsass.exe, GrantedAccess 0x1010
09:40:22	EDR	credential-access behaviour alert
09:42:30	4625 ×6	failed network logons: svc.finbackup, adm.kiran, administrator
09:44:50	4624 / 3	f.rao → FILE-SRV-03 over NTLM (she normally uses FILE-SRV-01 over Kerberos)
09:45:20	4648	explicit credentials for adm.kiran@FILE-SRV-03 — issued by dbgsvc.exe
09:45:25	4624 / 3 + 4672	adm.kiran on FILE-SRV-03 with SeBackup / SeDebug / SeTakeOwnership
09:45:40	4769 ×4	RC4 service tickets: cifs/FILE-SRV-03, MSSQLSvc/SQL-FIN-01, cifs/FILE-SRV-02, HOST/FIN-WS-121
09:47:05	5145 ×14	reads in Finance\$\Payroll
09:50:25	4624 / 3 + 4672	adm.kiran on FIN-WS-121 from FIN-WS-117

Answers: accounts — f.rao (session) and adm.kiran (abused). Process — dbgsvc.exe, **not signed, not trusted**, parent WINWORD.EXE, execution **not expected**. Systems authenticated to — FILE-SRV-03, FIN-WS-121 (tickets also requested for SQL-FIN-01, FILE-SRV-02). Attempts — 6 failed, 3 succeeded. Logon Type 3 — yes. Explicit credentials — yes (4648). Sensitive shares — yes (Finance\$). Another workstation — yes (FIN-WS-121). Unusual privilege assignment — yes (4672 on a file server and a peer workstation from a non-admin source).

 Mission 04 — Detection engineering: "Suspicious LSASS Process Access"

```
IF Sysmon EID 10 AND TargetImage endswith \lsass.exe
AND GrantedAccess includes memory-read (0x10 bit: 0x1010, 0x1410, 0x1438, 0x1fffff ...)
AND NOT (SourceImage on signed-path allow-list: MsMpEng, EDR agent, wininit, csrss)
THEN HIGH
  → raise to CRITICAL if, within 15 min from the SAME host:
    4648 for an admin/service account OR 4624 Type 3 to a file server from a non-PAW source
```

- Telemetry:** Sysmon 10 (SourceImage, TargetImage, GrantedAccess, CallTrace), Sysmon 1 / 4688 (parent, command line, hash, signature), EDR process telemetry, Security 4624/4648/4769.
- Why the access mask matters:** 0x1000 (query-limited) is what AV does all day; the 0x10 bit is what reading memory needs. Filtering on it removes most noise without an allow-list the attacker can imitate.
- Allow-list by signed full path, never by file name** — a file called MsMpEng.exe in %TEMP% must still fire (test 06).
- False positives:** new EDR/AV agent, WerFault on a real LSASS crash, approved admin tooling. **Severity:** ● HIGH alone, CRITICAL when correlated.
- Analyst response:** identify the source process → validate signature + hash → walk the parent chain → read the command line → check user context → hunt the hash fleet-wide → correlate with authentication from that host → escalate.
- Shipped as:** Sigma (4 rules + ordered temporal correlation), Wazuh rules 100840–100848, and the Python reference with tests. The rule never fires because lsass.exe exists (test 05).

 Mission 05 — Account & lateral-movement hunt

Hunt	Result	Hunt	Result
Logon Type 3 activity	✓ 3 from FIN-WS-117	Kerberos service-ticket anomalies	✓ 4 RC4 tickets
Explicit credential usage	✓ 4648 → adm.kiran	Privileged account usage	✓ adm.kiran + 4672 ×2
Failed authentication bursts	✓ 6 in 70 s	Same account on multiple endpoints	✓ FILE-SRV-03, FIN-WS-121
Logons from unusual hosts	✓ admin from a finance desktop	Same process/hash elsewhere	□ none (this host only)
SMB connections / finance shares	✓ Finance\$	Unusual sensitive-document access	✓ 14 payroll/treasury files
RDP attempts	□ none today	Processes created remotely	□ none observed — check FIN-WS-121
Remote administration activity	□ none ticketed	Auth right after the suspicious process	✓ 2 min 10 s later

Senior hunt question — which other systems? In this order: **(1) FIN-WS-117** — source; whose credentials were in memory decides everything else. **(2) DC-01** — every 4768/4769/4776 for f.rao, adm.kiran, svc.finbackup from 10.20.31.117; the DC is the only place that sees *all* ticket requests. **(3) FILE-SRV-03** — what was read, whether anything was written or scheduled. **(4) FIN-WS-121** — an admin logon to a peer workstation is where a second foothold would start. **(5) SQL-FIN-01 and FILE-SRV-02** — tickets were requested; a ticket is intent, check for the logon that follows. **(6) every host adm.kiran logged on to in the last 30 days** — his credential may be exposed there too.

Lateral movement vs legitimate administration is decided by five facts: source host (PAW or a desk?), ticket (exists or not?), authentication package (Kerberos AES or NTLM/RC4?), what preceded it (nothing, or an LSASS access?), and what followed (one maintenance task, or failed-burst → many SPNs → bulk reads?). Today every one of the five points the same way.

 Mission 06 — Incident containment plan

#	Action	Status / note
1	FIN-WS-117 network isolation (EDR isolate, keep powered on)	✓ verified — power-off would destroy memory evidence
2	User account status reviewed	✓ f.rao sessions revoked, password reset after evidence capture

#	Action	Status / note
3	Privileged accounts identified	✓ <code>adm.kiran</code> disabled + reset; <code>svc.finbackup</code> and built-in <code>administrator</code> reviewed (targeted in the failed burst)
4	Suspicious process preserved	✓ <code>dbgsvc.exe</code> quarantined as a copy, not deleted; the originating Word document collected
5	Process hash calculated	✓ hunted fleet-wide — no other host
6	LSASS access evidence preserved	✓ Sysmon 10 + EDR alert exported with CallTrace
7	Authentication timeline created	✓ Mission 03
8	FILE-SRV-03 activity reviewed	✓ 14 files listed for the data owner; check for writes/new tasks
9	Domain Controller logs preserved	✓ 4768/4769/4776 exported before rollover
10	Same account searched across endpoints	✓ FIN-WS-121 found → isolate and triage
11	Same process/hash searched	✓ none
12	Suspicious source IPs identified	✓ all internal (10.20.31.117); egress logs pulled for the document's origin
13	EDR telemetry + Security logs + endpoint forensics preserved	✓ memory image, MFT, prefetch, Office recent files
14	Business owner informed	✓ Finance head + payroll owner (salary and bank-mandate files were read)

Do NOT reimage yet. Reimaging first would erase the answers to the four questions that matter: **how it started** (the Word document and its delivery path), **what process did it** (binary, hash, memory), **which account** (which credentials were actually resident in LSASS — that list defines the reset scope), and **where it went next** (which only the preserved DC and file-server logs can prove). Reset order matters too: kill sessions and tickets for `adm.kiran` before resetting, and because RC4 service tickets were requested, rotate the passwords of the service accounts behind those SPNs.

Mission 07 — Correlation challenge

Is each event enough alone? **No.** A = an EDR agent could do it. B = users reach file servers all day. C = admins log on to workstations. D = finance staff open finance folders. Each has an innocent explanation and a high daily volume.

Correlated, the innocent explanations cancel out: the *same host* that showed the access (A) is the *source* of the Type 3 logon 4.5 minutes later (B), the *same account* reaches a peer workstation 10 minutes later (C), and the *same session* reads a share that account never read from that source (D). The hunter scores this **4/4 → CRITICAL**; with only A present it scores **1/4 → MEDIUM, H3 not supported** (test 16). Like a bank fraud desk: one late-night ATM withdrawal is nothing; a new device + a new city + a changed mobile number + a withdrawal in ten minutes is a blocked card.

Correlation is worth more because it (1) turns four low-confidence alerts into one high-confidence incident, (2) gives order and direction — cause before effect, source before destination, (3) defines scope automatically — the join keys *are* the list of hosts and accounts to contain, and (4) cuts analyst time: one case with a timeline instead of four tickets closed separately as "probably fine".

Senior SOC question — A (LSASS access) vs B (the chain)

B gives far stronger context. A answers "did something touch LSASS?" — B answers "was a credential taken *and used*, by which process, as which identity, against which server, to read what?"

- **Context:** A is a fact about one process; B attaches intent and impact to it.
- **Sequence:** order is evidence. Access → authentication → server → files inside ten minutes is a causal story; the same four events on four different days is not.
- **User identity:** the account changes mid-chain (`f.rao` → `adm.kiran`). That hand-off is invisible in any single event and is the clearest sign of credential theft.
- **Process lineage:** `WINWORD.EXE` → `dbgsvc.exe` → `lsass` and the 4648 issued *by the same binary* tie the endpoint story to the authentication story.
- **Host relationships:** workstation → file server → peer workstation is not an administrative path; PAW → server is.
- **Behavioural anomalies:** NTLM where Kerberos is normal, RC4 where AES is normal, a server this user never touches.
- **Reducing false positives:** A alone fires on every unlisted security tool; B needs two or more independent signals joined on host and account, so benign noise almost never completes the chain — while the attacker cannot skip steps without giving up the objective.

Modern detection engineering is therefore less about a perfect single rule and more about **cheap, honest atomic signals plus a correlation layer keyed on identity, host and time.**

MITRE ATT&CK map

T1204.002 User Execution (malicious file) · **T1003.001 OS Credential Dumping: LSASS Memory** · T1110 Brute Force (failed burst) · T1078.002 Valid Accounts: Domain · T1550.002 Use Alternate Authentication Material · T1558.003 Kerberoasting-style RC4 service tickets · **T1021.002 Remote Services: SMB** · T1039 Data from Network Shared Drive

References: MITRE ATT&CK T1003 / T1003.001 / T1078 / T1021; Microsoft Windows Security Auditing docs; Wazuh documentation; SigmaHQ. All data synthetic — detection and response only.